INSTITUTO TECNOLÓGICO DE COSTA RICA
ESCUELA DE INGENIERÍA EN COMPUTADORES
CE-1115 Seguridad de la Información

Proyecto · Parte 1 · Diseño del control de acceso

Matriz de control de acceso

Entregable 3 de 5

Cliente

Verdeazul Carbono S.A.
Certificación de captura de carbono · Pérez Zeledón, Costa Rica

Grupo 6

Integrante	**Carné**
Randall Bryan Bolaños López	2019043784
Javier Tenorio Cervantes	2020065308
Julio Varela Venegas	2019008041
Axel Flores Lara	2021453573

Prof. MSc. Andrés Vargas Rivera
Semestre II, 2026

Fecha de entrega: 15 de octubre de 2026

Índice

1. Cómo se lee esta matriz **1**

1.1. Sujetos 1

1.2. Objetos 2

1.3. Permisos 2

2. La matriz **3**

3. Reglas de las celdas condicionadas **4**

4. Restricciones entre roles **7**

5. Dónde se ve la separación de responsabilidades **8**

6. Justificación de mínimo privilegio **9**

7. Comprobación celda por celda **9**

8. Qué respondió el cliente y qué cambió en la matriz **11**

Referencias **13**

1 Cómo se lee esta matriz

Esta es la versión comprobable del diseño: cada decisión del documento de control de acceso (Entregable 2) termina aquí convertida en una celda. Las filas son los **sujetos**, las columnas son los **objetos** y cada celda dice qué puede hacer ese sujeto sobre ese objeto.

Tres reglas de lectura valen para toda la matriz:

1. **Lo que no está escrito está denegado.** El sistema niega por omisión. Una celda con — significa que el sujeto no tiene ningún permiso sobre el objeto, y dentro de una celda con permisos, toda operación que no aparezca también se deniega.
2. **Una condición solo puede quitar.** Un permiso con una marca $^{\mathbf{C}n}$ se concede únicamente si la regla C*n* de la sección 3 se cumple en ese momento. Las condiciones nunca amplían lo que el rol permite.
3. **La marca $^{\mathbf{H}}$ indica vigilancia por historial.** Las lecturas marcadas pasan además por los controles H1 a H3 (frecuencia, horario y combinación de ambos), que responden de forma graduada: avisan, piden una confirmación adicional o restringen por un tiempo.

Las marcas como **[minuta P-07]** indican que la regla sale de una respuesta del cliente, recogida en la minuta (Anexo A del informe de políticas). Las marcas como [supuesto P-13] indican un supuesto que el equipo fijó y documentó porque el cliente no dio el dato. El resumen está en la sección 8.

1.1 Sujetos

Sigla	Sujeto	Quién es en Verdeazul
TEC	Técnico de campo	Visita la finca, mide y registra. Trabaja con las fincas que tiene asignadas.
VER	Verificador	Revisa la medición desde la oficina y la aprueba o la devuelve. Por excepción puede medir, con una habilitación temporal de técnico. **[minuta P-01]**
SUP	Supervisor de campo	Coordina al personal de campo: asigna y reasigna las fincas y atiende las alertas de sus técnicos. **[minuta P-05]**
GER	Gerencia de Certificación	Responsable del dato. Incluye a la coordinación de certificación: decide los períodos y da la autorización final de las enmiendas y la segunda firma. **[minuta P-05, P-07]**
ADM	Administrador de catálogo y cuentas	Personal administrativo: mantiene el catálogo de fincas, registra los períodos y da de alta y de baja las cuentas.
AUD	Auditor externo	Revisa una vez al año, en sitio o a distancia. Ve todo, exporta evidencia y no modifica nada. **[minuta P-18]**
DUE	Dueño de finca	El titular, persona física o sociedad, o su representante autorizado. Consulta lo de sus fincas. **[minuta P-15]**
SIS	Procesos del sistema	Emisión de certificados, escritura de la bitácora y motor de alertas. No hay una persona detrás.
OPE	Operador de plataforma	Personal que la empresa designa para administrar servidores y respaldos. No tiene cuenta en la aplicación. **[minuta P-23]**
PUB	Público sin autenticar	Cualquiera que tenga en la mano el código de un certificado, por ejemplo un comprador. **[minuta P-04]**

Los siete primeros son los roles del modelo RBAC. **SIS** es una identidad de servicio. **OPE** y **PUB** aparecen en la matriz para dejar escrito qué no pueden hacer: quien custodia la infraestructura no tiene permisos sobre los datos del negocio, y quien no se identifica solo puede comprobar un certificado.

1.2 Objetos

Objeto	Qué contiene
Fincas y parcelas	Catálogo: finca, parcelas con su geometría y área, ubicación y titular asociado.
Datos personales del dueño	Identificación y contacto del titular y de sus representantes.
Períodos de medición	Fechas de inicio, de fin de medición y de cierre de registro, y estado: PLANIFICADO, ABIERTO, CERRADO.
Asignaciones	Qué técnico mide qué finca: *ordinaria*, por el período, o *temporal* (apoyo, sustitución o visita extraordinaria), con fecha de fin.
Mediciones	Registro de campo por parcela y período, con todas sus versiones, su fecha de medición y de registro, y su estado: BORRADOR, ENVIADA, DEVUELTA, APROBADA, EXCLUIDA.
Enmiendas	Solicitud, corrección propuesta, revisión técnica y autorización final de un cambio sobre una medición aprobada o de un período cerrado.
Certificados	Certificados de carbono emitidos, VIGENTE o REVOCADO, con el enlace entre el revocado y su reemplazo.
Cuentas y roles	Usuarios, su rol, su vigencia, sus credenciales y los vínculos que declaran con titulares.
Bitácora	Registro de quién hizo o consultó qué, cuándo y con qué resultado.
Alertas de historial	Avisos que generan los controles H1 a H3, con su nivel y su resolución.

1.3 Permisos

Se usan los verbos del dominio en lugar de siglas, para que la matriz se pueda leer proyectada: **leer**, **crear**, **modificar**, **eliminar** y **aprobar**, más los que el negocio necesita: **enviar** y **devolver** una medición; **solicitar**, **corregir**, **revisar** y **autorizar** una enmienda; **emitir** y **revocar** un certificado; **abrir** y **cerrar** un período; **proponer** un cambio que otra persona debe aprobar; **desactivar** una cuenta; **resolver** una alerta; **exportar** evidencia; **comprobar** un certificado y **anexar** a la bitácora.

El permiso **eliminar** no aparece en ninguna celda de mediciones, enmiendas, certificados, cuentas ni bitácora. Es una decisión de diseño: en esos objetos nada se borra, todo cambio queda como una versión nueva o como un cambio de estado.

2 La matriz

Sujeto ↓	**Fincas y parcelas**	**Datos pers. del dueño**	**Períodos de medición**	**Asigna-ciones**	**Mediciones**	**Enmiendas**	**Certificados**	**Cuentas y roles**	**Bitácora**	**Alertas de historial**
TEC	leer[C1]	leer[C1] solo contacto	leer	leer[C1] las propias	leer[C1] crear[C2] modificar[C2] enviar[C2]	leer[C1] solicitar[C7] corregir[C9]	—	modificar[C13]	—	—
VER	leer[H]	—	leer	—	leer[H] aprobar[C3] devolver[C3]	leer solicitar[C7] revisar[C10]	leer[H]	modificar[C13]	—	—
SUP	leer[H]	—	leer	leer crear[C19] modificar[C19]	leer[H] solo estado y fechas	leer solo estado	—	modificar[C13]	—	leer[C15] resolver[C15]
GER	leer[H] aprobar[C11]	leer[H]	leer abrir[C14] cerrar[C14]	leer	leer[H]	leer solicitar[C7] autorizar[C8]	leer[H]	leer aprobar[C12] modificar[C13]	leer	leer resolver[C15]
ADM	leer[H] proponer[C11]	leer[H] crear modificar eliminar[C16]	leer crear proponer[C14]	—	—	—	—	leer crear[C12] desactivar[C12] proponer[C12] modificar[C13]	—	—
AUD	leer[C6] exportar[C18]	leer[C6]	leer[C6] exportar[C18]	leer[C6] exportar[C18]	leer[C6] exportar[C18]	leer[C6] exportar[C18]	leer[C6] exportar[C18]	leer[C6] modificar[C13]	leer[C6] exportar[C18]	leer[C6] exportar[C18]
DUE	leer[C5]	leer[C5]	leer	leer[C5]	leer[C5] solo aprobadas	leer[C5]	leer[C5]	modificar[C13]	—	—
SIS	leer	leer solo nombre del titular	leer	leer	leer	leer	emitir[C4] revocar[C4]	—	anexar	crear
OPE	—	—	—	—	—	—	—	—	—	—
PUB	—	—	—	—	—	—	comprobar[C20]	—	—	—

Leyenda. — sin acceso: se deniega. [C*n*] permiso sujeto a la regla C*n* (sección 3). [H] lectura vigilada por los controles de historial H1 a H3. Toda operación no escrita en una celda está denegada. **C17** (abstención por vínculo) condiciona además todo verbo que no sea *leer* de TEC, VER, SUP, GER y ADM sobre fincas, asignaciones, mediciones y enmiendas. *Aprobar*, *devolver*, *revisar*, *autorizar*, *abrir*, *cerrar*, *resolver* y *exportar* exigen reautenticación con segundo factor en los cinco minutos previos. **OPE:** su acceso a la infraestructura se trata en el documento de arquitectura.

3 Reglas de las celdas condicionadas

Cada regla se escribe de forma que se pueda comprobar con un caso de prueba: dada una situación concreta, el sistema concede o deniega. En las reglas, *s* es el sujeto que hace la petición, *m* una medición, *e* una enmienda y *Autores*(m) es el conjunto de personas que registraron o modificaron cualquier versión de *m*. La columna *Depende de* indica si la regla mira el **estado** del sistema, el **historial** del sujeto o un **atributo** del objeto.

Id.	Nombre	Regla: el permiso se concede solo si…	Depende de	Celdas
C1	Asignación vigente	existe una asignación de *s* a la finca del objeto y la fecha actual cae dentro de su vigencia: la *ordinaria* vale mientras el período esté ABIERTO; la *temporal*, hasta su fecha de fin. También si *s* es el técnico que debe corregir una enmienda en trámite sobre esa finca. Además, siempre puede leer las mediciones que él mismo registró. **[minuta P-11]**	Estado, atributo y tiempo	TEC: fincas, datos, asignaciones, mediciones, enmiendas
C2	Edición solo en borrador	se cumple C1, el período de *m* está ABIERTO, *m* está en BORRADOR o DEVUELTA, y *s* es su autor o el técnico a quien SUP reasignó la finca; en ese caso el cambio es una versión nueva, con *s* como autor. La fecha de medición que *s* declara cae dentro del período y de su asignación, y no es posterior a la de registro, que pone el servidor. *Enviar* pasa *m* a ENVIADA y la deja fuera del alcance del técnico. **[minuta P-22]**	Estado e historial	TEC: mediciones
C3	Quien registró no aprueba	*m* está ENVIADA y $s \notin$ *Autores*(m). Vale con el período ABIERTO o ya CERRADO: el cierre detiene el registro, no la revisión de lo que se envió a tiempo. La regla mira todas las versiones: vale aunque *s* haya cambiado de rol o haya medido con una habilitación temporal. **[minuta P-01, P-06]**	Historial y estado	VER: mediciones
C4	Emisión única	la medición está APROBADA, quien la aprobó no está en *Autores*(m) y **no existe otro certificado VIGENTE para la misma parcela y el mismo período**. *Revocar* solo ocurre por una enmienda autorizada (C8) que cambia las toneladas certificadas: en una sola transacción el certificado anterior pasa a REVOCADO y se emite el nuevo, enlazados entre sí. Si las toneladas no cambian, el certificado sigue VIGENTE y se le anota la enmienda. Ninguno se borra. **[minuta P-08]**	Estado	SIS: certificados
C5	Solo lo suyo	*s* tiene una relación vigente con el titular de la finca a la que pertenece el objeto: es el titular o un representante que este autorizó. El titular puede ser una persona física o una sociedad, y tener varias fincas. En mediciones, además, solo las que están APROBADAS. **[minuta P-15]** [supuesto P-16]	Atributo	DUE: todas sus lecturas
C6	Ventana de auditoría	la fecha actual está dentro de la ventana de vigencia de la cuenta de auditor, que GER fija al activarla. Fuera de la ventana la cuenta no puede iniciar sesión, ni en sitio ni a distancia. Prorrogarla es una autorización nueva de GER. **[minuta P-18]**	Estado (tiempo)	AUD: todas

Id.	Nombre	Regla: el permiso se concede solo si…	Depende de	Celdas
C7	Solicitar enmienda	*m* está APROBADA, o su período está CERRADO y *m* quedó DEVUELTA o EXCLUIDA. La solicita el técnico responsable de *m* (TEC), un verificador (VER) o la Gerencia (GER), con el error que encontró y su evidencia. **[minuta P-07]**	Estado e historial	TEC, VER, GER: enmiendas
C8	Autorización final	*e* tiene dictamen técnico favorable (C10) y *s* no la solicitó, no la revisó ni figura en $Autores(m)$. Si *e* revoca un certificado, *s* deja registrado si ya fue comercializado y qué se acordó con el dueño. **[minuta P-07, P-08]**	Historial y estado	GER: enmiendas
C9	Corregir dentro del plazo	*e* está SOLICITADA, *s* es el técnico responsable de *m* o el que SUP designó en su ausencia, y no han pasado 10 días hábiles desde la solicitud. La corrección se guarda como versión *propuesta*: la versión vigente no cambia hasta la autorización final. **[minuta P-03]**	Estado (tiempo)	TEC: enmiendas
C10	Revisión técnica independiente	*e* tiene su corrección registrada, $s \notin Autores(m)$ y *s* no es quien solicitó *e*. Si la enmienda es *material* (cambia un dato que entra en el cálculo de las toneladas, o *m* ya tiene un certificado emitido), *s* tampoco es quien aprobó la versión que se corrige. La clasificación la calcula el sistema al comparar las dos versiones. **[minuta P-07]**	Historial	VER: enmiendas
C11	Catálogo con segunda firma	el alta de una finca, el cambio de titular y todo cambio de geometría o área que propone ADM quedan en estado PROPUESTO y solo surten efecto cuando GER los aprueba. El sistema rechaza una parcela cuya geometría se traslape con otra parcela activa. Una parcela con mediciones o certificados no se edita: se crea una versión nueva. [supuesto P-21]	Estado	ADM y GER: fincas
C12	Nadie se administra a sí mismo	la cuenta afectada no es la de *s*. Asignar los roles TEC, VER, SUP, GER, ADM o AUD es una propuesta de ADM que solo surte efecto cuando la aprueba GER, y quien aprueba no es ni quien propone ni el titular de la cuenta. La habilitación temporal de técnico para un verificador sigue la misma vía y lleva fecha de fin. El sistema rechaza toda asignación que viole las restricciones de la sección 4. **[minuta P-01]** [supuesto P-20]	Atributo e historial	ADM y GER: cuentas y roles
C13	Credenciales y declaración propias	la cuenta es la de *s* y el cambio se limita a su contraseña, sus factores de autenticación y su declaración de vínculos con titulares. La declaración se puede ampliar; retirar un vínculo lo aprueba GER.	Atributo	Todos los roles: cuentas
C14	Apertura y cierre entre dos	ADM registró la apertura o el cierre con las fechas que indicó la coordinación de certificación, y GER lo aprueba: ninguno de los dos pasos basta solo. No existe la operación *reabrir*. Al cerrar, lo ENVIADO sigue su revisión (C3), los borradores que nunca se enviaron pasan a EXCLUIDA y lo DEVUELTO solo cambia por enmienda. **[minuta P-05, P-06]**	Estado	ADM y GER: períodos

Id.	Nombre	Regla: el permiso se concede solo si…	Depende de	Celdas
C15	Alertas ajenas	el sujeto de la alerta no es *s*. SUP atiende las de los técnicos que tiene a cargo; GER, las de todos los demás y las que SUP no resuelva en dos días hábiles. Las alertas sobre GER se notifican a la Gerencia General y quedan visibles para el auditor externo. **[minuta P-10]**	Atributo	SUP y GER: alertas
C16	Supresión condicionada	no hay obligación vigente de conservar el dato: los datos personales ligados a un certificado emitido se conservan mientras dure la trazabilidad exigida y después se desasocian del titular.	Estado (tiempo)	ADM: datos personales
C17	Abstención por vínculo	*s* no tiene declarado un vínculo familiar o comercial con el titular de la finca del objeto. Quien lo tiene no mide, no aprueba, no asigna, no revisa ni autoriza nada sobre esa finca: el sistema lo pasa a otra persona. **[minuta P-15]**	Atributo	Las que indica la leyenda de la matriz
C18	Exportar evidencia	se cumple C6 y lo exportado es un paquete que genera el sistema: va sellado, lleva la identidad del auditor y su huella queda en la bitácora. El titular aparece por su código; los datos personales no se exportan. **[minuta P-18]**	Estado (tiempo)	AUD: todas menos datos personales y cuentas
C19	Asignar con vigencia	el asignado tiene el rol TEC vigente, propio o por habilitación temporal, y no es *s*. La asignación es ordinaria, por el período, o temporal, con motivo y fecha de fin: 15 días como máximo, renovable. **[minuta P-05, P-11]**	Atributo y tiempo	SUP: asignaciones
C20	Comprobación pública	quien consulta presenta el código impreso en el certificado. Recibe solo si el sello es válido, el estado, las toneladas, el período y, si fue revocado, el código del que lo reemplaza. No hay listados, búsquedas ni datos del titular. **[minuta P-04]**	Atributo	PUB: certificados

Controles de historial sobre las lecturas marcadas con ^{H}. Su definición completa está en el documento de control de acceso; aquí se resume lo necesario para comprobarlos. Los umbrales son parámetros por rol que aprueba GER, no constantes. **[minuta P-02]**

Id.	Tipo	Regla	Decisión
H1	Frecuencia	Número de fincas distintas cuyo detalle consultó *s* en las últimas 24 horas, comparado con los tres umbrales de su rol. Los intentos denegados por C1 o C5 cuentan doble. **[minuta P-10]** [supuesto P-13]	Conceder; conceder y avisar; conceder con segundo factor y motivo; o restringir las fincas nuevas hasta el siguiente día hábil.
H2	Tiempo	Una acción de decisión se pide fuera de la jornada del rol. [supuesto P-12]	Conceder con segundo factor y motivo.
H3	Combinada	Fuera de jornada, más fincas distintas en 60 minutos que el umbral (inicial: 10) y la mayoría nunca consultadas por *s* en los últimos 90 días. **[minuta P-10]**	Conceder con segundo factor y motivo, y avisar de inmediato. Si la pauta sigue, restringir las fincas nuevas hasta el siguiente día hábil.
H4	Secuencia	Quien participó en un paso anterior del flujo no decide el siguiente. Es el nombre que reciben, como control de historial, las reglas C3, C8 y C10.	Denegar.

4 Restricciones entre roles

La matriz supone que una persona tiene una sola identidad en el sistema y que los roles no se acumulan. Son las restricciones del nivel $RBAC_2$ de Sandhu *et al.* (1996), y el sistema las valida cada vez que se asigna un rol (regla C12).

	TEC	VER	SUP	GER	ADM	AUD	DUE
TEC	—	**D**	×	×	×	×	×
VER	**D**	—	×	×	×	×	×
SUP	×	×	—	×	×	×	×
GER	×	×	×	—	×	×	×
ADM	×	×	×	×	—	×	×
AUD	×	×	×	×	×	—	×
DUE	×	×	×	×	×	×	—

× = exclusión estática: ninguna persona puede tener ambos roles. **D** = exclusión dinámica: una persona puede tener ambos, pero nunca activos en la misma sesión.

- **Un rol por persona, con una sola excepción.** El cliente confirmó que algunos verificadores fueron técnicos y que, en situaciones excepcionales, pueden colaborar midiendo. Un verificador puede recibir una **habilitación temporal de técnico**, con fecha de fin, que propone ADM y aprueba GER (C12). Mientras dure, entra como técnico o como verificador, nunca como ambos a la vez. La separación no descansa en esa casilla sino en la regla C3, que mira cada medición: lo que midió con la habilitación no lo podrá aprobar nunca. **[minuta P-01]**
- **Una identidad por persona.** La cuenta se liga al número de identificación; el sistema no admite dos cuentas activas para la misma persona.
- **Cardinalidad.** Al menos dos cuentas VER activas mientras haya mediciones sin dictamen, para que C3 nunca deje una medición sin nadie que pueda aprobarla. Es el mínimo que exige una revisión independiente, no un supuesto de tamaño: ninguna regla depende de cuántos técnicos, verificadores o fincas haya. El número de personas con rol GER o ADM tiene un tope que fija la Gerencia General. **[minuta P-02]**

- **Dueños y personal interno.** DUE es excluyente con todos los roles internos. Si un empleado es titular de una finca certificada, el acceso como dueño lo ejerce un representante. Y como no existe un registro que descarte los vínculos familiares o comerciales, todo el personal declara los suyos al ingresar y antes de cada período; la regla C17 lo aparta de esas fincas. **[minuta P-15]**

5 Dónde se ve la separación de responsabilidades

La acción que ninguna persona puede completar sola es la **emisión de un certificado**. En la matriz eso se lee siguiendo la columna *Mediciones* hacia *Certificados*:

Paso del flujo	Celda	Qué impide
Registrar y enviar	(TEC, Mediciones): crear, modificar, enviar[C2]	El técnico no tiene *aprobar*. Después de enviar ya no puede modificar.
Aprobar o devolver	(VER, Mediciones): aprobar, devolver[C3]	El verificador no tiene *crear* ni *modificar*, y no aprueba una medición en la que participó, aunque haya sido en otro puesto o con una habilitación temporal.
Emitir	(SIS, Certificados): emitir[C4]	Ninguna persona tiene *emitir*. El sistema emite solo si los dos pasos anteriores los hicieron personas distintas y no hay otro certificado vigente para la misma parcela y período.

El mismo patrón, quien inicia no cierra, se repite en otras cinco columnas:

Columna	Quién hace cada paso	Reglas
Enmiendas	Solicita TEC, VER o GER; corrige TEC; revisa un VER que no es autor ni solicitante; autoriza GER, que no solicitó ni revisó. Cuatro pasos y al menos tres personas.	C7 a C10
Períodos de medición	Registra ADM; abre y cierra GER.	C14
Asignaciones	Asigna SUP; mide TEC. Nadie se asigna a sí mismo.	C19
Fincas y parcelas	Propone ADM; aprueba GER.	C11
Cuentas y roles	Propone ADM; aprueba GER; nadie toca su propia cuenta.	C12

Registrar, modificar, revisar y aprobar son cuatro permisos distintos. El cliente pidió que el diseño los distinga, porque al cerrar un período pueden quedar mediciones pendientes de revisión. **[minuta P-06]** Así se comporta cada uno:

Acción	Verbo y celda	Con el período abierto	Con el período cerrado
Registrar	crear (TEC)	El técnico asignado.	Nadie.
Modificar	modificar (TEC)	El autor, si está en borrador o devuelta.	Nadie. Solo por enmienda (C7 a C10).
Revisar	leer, devolver (VER)	Cualquier verificador.	Cualquier verificador, sobre lo que se envió a tiempo.
Aprobar	aprobar (VER)	Un verificador que no participó.	Igual: el cierre no lo impide.

6 Justificación de mínimo privilegio

Por cada permiso amplio de la matriz, por qué no puede ser más estrecho y qué lo acota.

Permiso amplio	Por qué no puede ser más estrecho	Qué lo acota
AUD lee los diez objetos y exporta evidencia	El cliente lo exige: los auditores «necesitan ver absolutamente todo» y, en ocasiones, llevarse evidencia para sus informes.	Ningún verbo de escritura; ventana de vigencia (C6); cuentas nominales; la exportación es un paquete sellado, registrado y sin datos personales (C18).
GER lee todo el negocio y la bitácora	Autoriza enmiendas, atiende alertas y responde ante el auditor: sin ver la medición, el certificado y el rastro no puede decidir.	No crea, modifica ni aprueba mediciones; no asigna fincas; no emite; vigilancia H1 a H3; no resuelve sus propias alertas (C15).
VER lee mediciones, fincas y certificados de cualquier finca	La cola de verificación abarca cualquier finca del período y el dictamen compara contra el historial de la parcela y sus certificados anteriores.	Sin acceso a datos personales del dueño ni a asignaciones; vigilancia H1 a H3; abstención por vínculo (C17).
SUP lee el catálogo y crea asignaciones de cualquier finca	Coordina al personal de campo y debe poder reasignar por vacaciones, incapacidades o visitas extraordinarias.	De las mediciones solo ve estado y fechas; no ve datos personales; no se asigna a sí mismo (C19); las temporales vencen solas; cada asignación va al resumen semanal de GER.
ADM lee y mantiene todo el catálogo y los datos personales	Es su función: administrar el catálogo, habilitar las cuentas de los dueños y atender sus solicitudes de rectificación.	Sin acceso a mediciones, enmiendas, certificados ni bitácora; todo cambio de geometría o de titular requiere a GER (C11).
ADM crea y desactiva cuentas y registra períodos	Alguien tiene que dar de alta y de baja al personal el mismo día en que entra o sale, y registrar las fechas que decide la coordinación.	No asigna roles por sí solo ni toca su propia cuenta (C12); un período no se abre ni se cierra sin GER (C14).
TEC crea y modifica mediciones	Es su trabajo, y debe poder corregir lo que el verificador le devuelve.	Solo en fincas asignadas, solo sus propios borradores y solo con el período abierto (C1, C2).
DUE lee todo lo de sus fincas	El cliente lo pide: «sus mediciones, sus certificados».	Solo lo propio (C5) y solo mediciones aprobadas; ninguna escritura.
SIS emite y revoca certificados	La emisión debe ocurrir sin que una persona tenga ese permiso.	Solo bajo C4; ninguna persona puede invocar la emisión directamente.
PUB comprueba un certificado	El cliente quiere poder demostrar ante terceros que un certificado es auténtico y cuál es su estado.	Solo con el código del certificado; respuesta mínima, sin listados ni datos del titular (C20); límite de ritmo por origen.

7 Comprobación celda por celda

Para que la matriz sea verificable por alguien que no participó en el diseño, cada regla se acompaña de al menos un caso de prueba con su resultado esperado. El equipo que construya el sistema debe convertirlos en pruebas automáticas y ejecutar además una prueba por cada celda marcada con —.

Caso	Situación	Resultado	Regla
T-01	El técnico A, asignado a la finca F1 en un período abierto, crea una medición en F1.	Concede	C1, C2
T-02	El técnico A pide el detalle de la finca F2, que no tiene asignada.	Deniega	C1; suma a H1
T-03	El técnico A intenta modificar una medición suya que ya está ENVIADA.	Deniega	C2
T-04	El técnico A intenta modificar un borrador suyo después del cierre del período.	Deniega	C2, C14
T-05	El verificador B aprueba una medición registrada por A.	Concede	C3
T-06	La verificadora C, que el año pasado era técnica y registró la versión 1 de una medición, intenta aprobarla.	Deniega	C3
T-07	Se aprueba una segunda medición de la misma parcela y período que ya tiene certificado vigente.	No emite	C4
T-08	El dueño D cambia en la dirección el identificador de su certificado por el de otro dueño.	Deniega[b]	C5
T-09	La auditora E inicia sesión una semana después de terminada su ventana.	Deniega	C6
T-10	La auditora E, dentro de su ventana, envía una petición de modificación sobre cualquier objeto.	Deniega	Fila AUD
T-11	El técnico A solicita una enmienda sobre una medición que registró otro técnico.	Deniega	C7
T-12	La gerente G autoriza una enmienda que solicitó y corrigió A y que tiene dictamen favorable de C.	Concede	C8
T-13	El técnico A registra la corrección once días hábiles después de la solicitud.	Deniega	C9
T-14	El verificador B, que solicitó la enmienda, intenta dar el dictamen técnico.	Deniega	C10
T-15	El administrador propone una parcela que se traslapa con otra activa.	Deniega	C11
T-16	El administrador se asigna a sí mismo el rol VER.	Deniega	C12
T-17	Se cierra el período; después B aprueba una medición que A envió antes del cierre.	Concede	C3, C14
T-18	El verificador B consulta en un día más fincas distintas que el umbral de verificación de su rol.	Pide segundo factor y motivo	H1
T-19	Un sábado a las 23:00, B abre en una hora el detalle de 11 fincas que nunca había consultado.	Pide segundo factor y motivo, y avisa a GER	H3
T-20	El operador de plataforma intenta iniciar sesión en la aplicación.	Deniega	Fila OPE
T-21	Después del cierre, A intenta modificar una medición que B le devolvió.	Deniega: procede una enmienda	C2, C7
T-22	El administrador registra el cierre y GER aún no lo aprueba; A crea una medición.	Concede: el período sigue abierto	C14
T-23	Enmienda material: B, que aprobó la versión que se corrige, intenta dar el dictamen técnico.	Deniega	C10
T-24	La gerente G, que solicitó una enmienda, intenta autorizarla.	Deniega	C8
T-25	Se autoriza una enmienda que cambia las toneladas de un certificado vigente.	Revoca y emite el reemplazo en un solo paso	C4

Caso	Situación	Resultado	Regla
T-26	La verificadora C, con habilitación temporal de técnica, registra una medición y después, en otra sesión, intenta aprobarla.	Deniega	C3
T-27	El supervisor S da a A una asignación temporal a F2 por tres días; al cuarto, A pide el detalle de F2.	Deniega	C1, C19
T-28	El supervisor S intenta asignarse a sí mismo una finca.	Deniega	C19
T-29	B declaró un vínculo con el titular de F5 e intenta aprobar una medición de F5.	Deniega	C17
T-30	A registra una medición con fecha de medición posterior a la de hoy, o fuera del período.	Deniega	C2
T-31	La auditora E exporta la evidencia de un certificado dentro de su ventana.	Concede: paquete sellado, sin datos personales	C18
T-32	Un comprador, sin cuenta, consulta el código de un certificado revocado.	Responde «revocado» y el código del reemplazo	C20
T-33	B, después de confirmar en T-19, abre otras diez fincas que nunca había consultado.	Restringe las fincas nuevas y avisa	H3
T-34	B aprueba una medición un domingo por la tarde.	Pide segundo factor y motivo	H2
T-35	El técnico A intenta cambiar la contraseña de otra cuenta.	Deniega	C13
T-36	El supervisor S intenta resolver una alerta sobre sí mismo.	Deniega	C15
T-37	El administrador intenta suprimir los datos de un titular con un certificado emitido hace tres años.	Deniega	C16

[b] La respuesta es «no encontrado», igual que si el certificado no existiera, para no revelar la existencia de datos de otro dueño. Los casos T-21 a T-37 se agregaron después de la consulta al cliente; T-12, T-13, T-17, T-18 y T-19 cambiaron con ella.

8 Qué respondió el cliente y qué cambió en la matriz

La primera versión de la matriz se construyó con supuestos de trabajo. El cliente respondió por escrito catorce de las veintiséis consultas del equipo; la minuta completa es el Anexo A del informe de políticas. Esto es lo que cada respuesta cambió aquí.

Consulta	Lo que respondió el cliente	Qué cambió en la matriz
P-01	Un verificador puede medir, por excepción. Hace falta revisión independiente sin impedir que el personal asuma otras tareas.	La exclusión TEC–VER pasó de estática a dinámica, con habilitación temporal (C12). C3 no cambió. Caso T-26.
P-02	No hay cifras de personal ni de fincas; el diseño no debe depender de cantidades fijas.	Los umbrales de H1 y H3 son parámetros por rol. El tope de GER y ADM dejó de ser un número fijo.
P-03	El verificador devuelve con observaciones; no modifica mediciones ajenas.	Confirmado: (VER, Mediciones) no tiene *crear* ni *modificar*, y en la enmienda corrige el técnico (C9).

Consulta	Lo que respondió el cliente	Qué cambió en la matriz
P-04	Interesa demostrar la autenticidad del certificado, su estado y quién autorizó su emisión.	Fila PUB y regla C20: comprobación pública con el código del certificado.
P-05	La coordinación de certificación decide los períodos y el personal administrativo los registra. Las fincas las asignan los supervisores de campo.	Rol nuevo, SUP, con la columna *Asignaciones* (C19). *Períodos*: ADM registra y GER abre y cierra (C14). GER dejó de crear asignaciones.
P-06	Al cierre pueden quedar mediciones por revisar; el cierre impide registrar y modificar, no terminar la revisión.	C3 ya no exige el período abierto. C14 solo excluye los borradores nunca enviados. Casos T-17, T-21 y T-22.
P-07	Solicita el técnico responsable, un verificador o el personal de certificación; autoriza la Gerencia con una revisión técnica; los tres deben ser independientes.	La enmienda cambió de orden: solicitar, corregir, revisar, autorizar. C7, C8 y C10 se reescribieron y GER ganó *solicitar*. Casos T-12, T-23 y T-24.
P-08	Si cambian las toneladas hay que evaluar el certificado; nunca desaparece ni hay dos vigentes.	C4: revocar y reemitir en una sola transacción, con enlace entre ambos. C8: registro de si fue comercializado. Caso T-25.
P-10	Como mínimo detectar y avisar al supervisor o a la Gerencia; respuesta según la gravedad; no bloquear de inmediato.	H1 ganó un escalón de solo aviso; H3 pide confirmación antes de restringir. La columna *Alertas* tiene a SUP (C15). Casos T-19 y T-33.
P-11	El técnico trabaja con sus fincas asignadas, pero debe poder apoyar, sustituir y atender visitas extraordinarias.	C1 admite asignaciones temporales con fecha de fin, que crea SUP (C19). Caso T-27.
P-15	Los dueños entran; hay personas físicas y sociedades, con varias fincas y representantes. No hay registro de vínculos con empleados.	C5 reconoce titular y representante. Regla nueva C17, abstención por vínculo declarado, y C13 para declararlo. Caso T-29.
P-18	No hay una norma de auditoría definida. Auditan una vez al año, en sitio o a distancia, y a veces exportan evidencia.	Verbo *exportar* en la fila AUD (C18). C6 aclara que una prórroga es una autorización nueva. Caso T-31.
P-22	El registro puede hacerse después de la visita; importa la trazabilidad de las fechas de medición y de registro.	C2 valida la fecha de medición declarada contra el período, la asignación y la fecha de registro. Caso T-30.
P-23	La operación quedará en personal que la empresa designe.	La fila OPE se mantiene sin permisos; su descripción dejó de suponer un proveedor.

Supuestos que el equipo fijó. El cliente no respondió estas consultas y pidió que el equipo decida y justifique. La matriz usa estos valores; si cambian, cambia lo que indica la última columna.

Consulta	Supuesto declarado	Qué cambiaría
P-12	La jornada es de lunes a viernes, de 6:00 a 19:00. Es un parámetro por rol.	El valor de H2 y de H3.
P-13	Hasta calibrar con datos reales, los umbrales de H1 son 40, 60 y 80 fincas por día.	Los valores de H1.
P-16	El dueño ve una medición solo cuando está aprobada.	C5 en la celda (DUE, Mediciones).
P-20	La jefatura solicita la cuenta, ADM la crea y GER aprueba el rol.	C12 y la celda (GER, Cuentas y roles).
P-21	Una hectárea se identifica por la geometría de su parcela.	La restricción de traslape de C11.

Referencias

Lampson, B. W. (1974). Protection. *ACM SIGOPS Operating Systems Review, 8*(1), 18–24. https://doi.org/10.1145/775265.775268

Saltzer, J. H., & Schroeder, M. D. (1975). The protection of information in computer systems. *Proceedings of the IEEE, 63*(9), 1278–1308. https://doi.org/10.1109/PROC.1975.9939

Sandhu, R. S., Coyne, E. J., Feinstein, H. L., & Youman, C. E. (1996). Role-based access control models. *Computer, 29*(2), 38–47. https://doi.org/10.1109/2.485845

Vargas Rivera, A. (2026). *Material de estudio, clase 10: Matriz de control de acceso* [Material de clase]. Curso CE-1115 Seguridad de la Información, Instituto Tecnológico de Costa Rica.